

-

File No.: EXP202303035

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: Ms. A.A.A. (hereinafter, the complainant) filed a complaint with the Spanish Agency for Data Protection on January 20, 2023. The complaint is directed against BANCO PICHINCHA ESPAÑA, S.A. with NIF A85882330 (hereinafter, BANK).

In the received document, the following is reported:

The complainant states that her phone number ***PHONE.1, of which she is the owner, was cloned by the company DIGI SPAIN TELECOM, S.L.U. ("DIGI"), as on September 4, 2021, without any security measures aimed at reliably identifying the person who requested it, a third party, impersonating the complainant's identity, requested the cloning of the phone, with the purpose of making calls to the banking entity BANCO PICHINCHA ESPAÑA, S.A. and thus carrying out certain operations that resulted in a total of 50,000 euros transferred from her bank account to other accounts.

Along with the notification, a police report and complaints made are attached.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter LOPDGDD), this complaint was forwarded to DIGI, so that it could analyze it and inform this Agency within one month of the actions taken to comply with the requirements set forth in the data protection regulations.

The forwarding, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was recorded on March 8, 2023, as evidenced by the acknowledgment of receipt in the file.

On April 5, 2023, a response was received at this Agency indicating that "...in light of what the Complainant indicated in the complaint filed with the AEPD, on September 7, 2021, due to problems with her phone, she requested a copy of her SIM card from her telephone operator, as well as a list of outgoing calls made from her phone number, confirming that three (3) calls had been made to the PIBANK Customer Service phone number, which, according to the Complainant, had not been made by her.

Subsequently, as Ms. A.A.A. indicates, on September 28, 2021, she attempted to access PIBANK's Online Banking, discovering that her usual password generated an access error, which is why she contacted PIBANK's Customer Service through the contact number 911110000, in order to recover her Online Banking credentials.

When a customer requests the recovery of credentials for Online Banking at the Entity, the operator who answers the call must ask a series of security questions structured as mechanisms for customer identification defense, asking the customer questions whose answers would be easy for them to remember, but at the same time difficult for anyone else to guess. (...):

o

(...)

o

(...)

o

(...)

o

(...)

o

(...)

o

(...)

o

(...)

o
(...)
o
(...)
(...)
(...)

In relation to the above, it is noteworthy that, at the time of the events, the Bank had outsourced customer service to the entity GLOBAL SALES SOLUTIONS LINE, S.L., which was responsible, among other things, for handling incoming calls to the Entity..."

"...Although, as has been evidenced, the Bank had reiterated on different occasions, and through various means, to its Provider what the procedure was for a customer to recover their Online Banking credentials, as well as the specific instructions regarding the modus operandi of the operators in situations where the customer does not respond accurately and clearly to the questions asked, in the call made by the GSS operator to Ms. A.A.A. on September 6, 2021, at 12:13 hours, said operator did not strictly comply with the protocol established by the Entity, since, (...), the operator continued to ask more questions to the Complainant, ultimately initiating the process of automatically sending the corresponding OTP code via SMS to the phone number that the Complainant provided to the Bank at the time of account opening (let us remember that this number was verified by the Complainant herself at the time of contracting, as has been stated above), which would allow her to change the password for Online Banking.

In this regard, it is of interest to the Entity to inform this Agency that, despite being a call, which was subsequently considered as

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
3/30

fraudulent, a fact of which the Bank became aware later, through communications made by the Claimant days afterwards, the Bank made available to the Provider all the necessary tools to strictly comply with the current regulations, and having detected no signs of irregularity that would lead it to distrust a possible fraudulent contracting. In this sense, the Bank considers that, if there were a breach, it would be attributable to GSS, since Article 28.10 of the GDPR establishes that: "if a processor infringes this Regulation by determining the purposes and means of processing, it shall be considered responsible for the processing in relation to that processing."

In light of the above, and as has been evidenced, the Provider failed to comply with the instructions provided by the Bank, thus acquiring the status of data controller in this case...

THIRD: On April 20, 2023, in accordance with Article 65 of the LOPDGDD, the claim submitted by the claimant was admitted for processing.

FOURTH: According to the report collected from the AXESOR tool, the entity BANCO PICHINCHA ESPAÑA, S.A. is a medium-sized company established in 2010, with a turnover of 45,135,000 euros in 2022.

FIFTH: On October 2, 2023, the Director of the Spanish Data Protection Agency agreed to initiate sanctioning proceedings against the respondent party, for the alleged infringement of Article 6.1 of the GDPR, classified in Article 83.5 of the GDPR.

SIXTH: Once the aforementioned initiation agreement was notified in accordance with the rules established in the LPACAP, the respondent party submitted a written statement of allegations in which it requests that it be considered presented along with the accompanying documents, that they be admitted, and that the previous allegations be deemed formulated, and following the appropriate procedures, it is agreed:

- The filing of the referenced file, rendering the initiated sanctioning procedure ineffective.
- In the event that the previous request is not accepted by the Agency, it requests that the mitigating circumstances be taken into account and, consequently, that the procedure be concluded with a warning.

- In the hypothetical case that none of the previous requests are accepted by the AEPD; as a last resort, it requests that the amounts established in the Agreement be reduced, taking into account the arguments expressed in the body of the document.

In its allegations, in summary, the respondent party argues:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

4/30

1.- In its first allegation, BANCO refers to having had, at all times, sufficient and adequate legitimacy for the processing of the personal data of the claimant as a result of the formalization, management, and execution of the contractual relationship maintained by both parties. Regarding the impersonation, it considers that the Agency should attribute an infringement of Article 6 in relation to Article 7 of the GDPR to the one who obtained and used the claimant's data for illicit gain. BANCO also points out that it immediately proceeded to refund the amounts taken, despite the judicial dismissal of the proceedings. Finally, it refers to various resolutions of dismissal by the Spanish Data Protection Agency.

2.- In its second allegation, BANCO proceeds to analyze the disproportionality of the sanction, as well as the aggravating factors applied in the grading of the sanction, pointing out as mitigating factors for the purpose of reducing the administrative sanction:

- That the entity, acting in good faith, diligence, and proactivity, effectively resolved the incident that is the subject of the claim.

- The absence of facilitation of the personal data of the claimant to a third party along with the procedures instituted by the company.

- The non-existence of alleged prior infringements.

- The high degree of cooperation in order to offer and make available to this agency all information that was at its disposal.

- That the entity never provided any personal data to the identity thief.

- That the entity has never obtained any type of benefit.

Finally, it notes that the measures in place at the time of the events complied with the most rigorous standards to address the risks and were adequate and suitable considering the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, as well as the risks to the rights and freedoms of individuals.

However, the allegations presented were dismissed.

SEVENTH: On August 8, 2024, a resolution proposal was made, proposing that BANCO PICHINCHA ESPAÑA, S.A., with NIF A85882330, be sanctioned for an infringement of Article 6.1 of the GDPR, classified in Article 83.5 of the GDPR, with a fine of €50,000 (FIFTY THOUSAND EUROS).

EIGHTH: Once the resolution proposal was notified in accordance with the rules established in the LPACAP, the respondent party submitted a written statement of allegations on August 21, 2024.

In its allegations, in summary, the respondent party states:

1. In its first allegation, BANCO insists that it has always processed the personal data of Ms. A.A.A. (hereinafter, interchangeably, the "Claimant") on an adequate legal basis in accordance with the provisions of Article 6 of the GDPR and points out that the one who processed the data without sufficient legitimacy and, therefore, who should have had the...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/30

the consent of the Claimant for its proper treatment was the impersonator, incurring the AEPD in an error as stated in the Proposal for Resolution.

Finally, in this same allegation, it refers to the fact that the AEPD has not followed the same criterion

as the Court of Instruction No. 2 of Albacete regarding the dismissal, as well as the principle of certainty and the principle of in dubio pro reo.

2.

In its second allegation, BANCO insists on the absence of any type of responsibility for the actions carried out by GSS, as the data processor.

3.

In its third allegation, BANCO refers to jurisprudence that has determined that an action cannot be sanctioned without a certain degree of intent, as well as that the existence of a culpable infringement constitutes a requirement for the imposition of a fine.

4.

Finally, BANCO alleges the principle of proportionality stating that the proposed sanction is not appropriate and, in the hypothetical case that it were appropriate, it would not be proportional to the factual situation at hand.

It concludes its written allegations by stating that it attaches two proof of payments made in favor of the AEPD, of €40,000 and €10,000 respectively, and the reasons for making such payments. It is categorical that these are not an acknowledgment of the alleged facts, but rather that the intention is to avoid possible future accruals of interest.

From the actions taken in the present procedure and the documentation in the file, the following has been established:

PROVEN FACTS

FIRST: It is recorded in the file a complaint dated January 20, 2023, in which the claimant states that their phone number ***PHONE.1 was cloned by the company DIGI SPAIN TELECOM, S.L.U. ("DIGI"); since, on September 4, 2021, a third party requested the cloning of the phone by impersonating the identity of the claimant, with the aim of making calls to the banking entity BANCO PICHINCHA ESPAÑA, S.A. and thus carrying out certain banking operations.

SECOND: It is recorded in the file and as stated by the claimant, that on September 7, 2021, due to problems with their phone, they requested a copy of their SIM card from their phone operator, as well as a list of outgoing calls made from their phone number, verifying that three (3) calls had been made to the PIBANK Customer Service phone number, which the Claimant states were not made by them.

THIRD: It is recorded in the file and as stated by BANCO that, after making the appropriate checks, there are indeed three calls from the PIBANK Customer Service to the claimant's phone number.

FOURTH: It is recorded in the file and as stated by the respondent that in the call made by the GSS operator to the claimant on September 6, the operator did not strictly comply with the protocol established by BANCO, since "the supposed client" indicated in the call that they were unaware of the balance in their bank account, as well as doubts about their profession.

FIFTH: It is proven in the file that, as a result of the call on September 6, the automatic process of the corresponding OTP code via SMS is initiated, allowing the change of the Online Banking password and carrying out various financial operations.

SIXTH: It is proven in the file that the entity GSS is a provider of BANCO for the provision of advanced customer management services, by virtue of a service provision contract signed by both entities on June 25, 2019.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued for its development, and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Obligation breached

Article 4 of the GDPR, under the heading "Definitions," provides the following:

- "1) 'personal data': any information relating to an identified or identifiable natural person ('the data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier, such as a name, an identification number, location data, an online identifier, or one or more factors specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person;
- 2) 'processing': any operation or set of operations performed on personal data or sets of personal data, whether by automated means or not;"

7/30

automated or not, such as collection, recording, organization, structuring, preservation, adaptation or modification, extraction, consultation, use, communication by transmission, dissemination or any other form of enabling access, comparison or interconnection, limitation, suppression or destruction."

7) "data controller" or "controller": the natural or legal person, public authority, service or other body that, alone or jointly with others, determines the purposes and means of the processing; if Union law or the law of the Member States determines the purposes and means of the processing, the data controller or the specific criteria for its appointment may be established by Union law or the law of the Member States."

In this regard, it should be noted that the BANK is responsible for the processing of personal data and; therefore, determines the purposes and means of processing personal data.

III

Allegations to the proposed resolution

In response to the allegations presented by the entity being claimed against, the following should be noted, in the order presented:

The entity being claimed against alleges:

1. MANIFEST INTERNAL INCONGRUENCE OF THE PROPOSED RESOLUTION ISSUED AND THE MANIFEST VIOLATION OF THE RIGHT TO EFFECTIVE JUDICIAL PROTECTION

As has been conveyed to this Agency through the various submissions made, BANCO PICHINCHA has always processed the personal data of Ms. A.A.A. (hereinafter, interchangeably, the "Claimant") on an adequate legal basis in accordance with the provisions of Article 6 of the GDPR. In this sense, it should be brought to attention what is stated in the Proposal for Resolution by the AEPD, which highlights the manifest error it has incurred, said with due respect and in terms of strict defense:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/30

To the surprise of this party, the AEPD fails to reference that it is the impersonator who should have that consent, since it is the one who obtained and used the personal data of the claimant to gain an illicit benefit, without the data processor, GLOBAL SALES SOLUTIONS LINE, S.L (hereinafter, interchangeably, "GSS" or the "Data Processor") or the Entity needing to have that legal basis to carry out the actions corresponding to the contractual relationship, considering that said action consisted of impersonating the identity of the now Claimant.

Consequently, it is clear that if GSS or the Entity had had the consent, the type related to identity theft would imply a fading of the object that has given rise to the opening of this procedure, as well as the criminal complaint along with the dismissal of the corresponding process.

From the previous screenshot, the incongruence incurred by the Agency is evident, considering that the data processed from the Claimant were without sufficient legitimacy, when BANCO PICHINCHA maintained a contractual relationship with her that enabled its proper processing. A different matter is that the impersonator did not have the consent of the Claimant and, taking advantage of the information obtained through third parties, achieved the intended purpose as a result of an error by the

Data Processor regarding compliance with the security protocol (hereinafter, the "Protocol") provided by this party in the allegations to the initiation agreement of the sanctioning procedure. Protocol C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
9/30

which certifies that the Entity had adequate technical security measures that allowed for the proper processing of the personal data of clients in accordance with the provisions of Article 32 of the GDPR. In conclusion, as can be seen from the following screenshot, the party that processed the data without sufficient legitimacy and, therefore, who should have obtained the consent of the Claimant for its proper processing was the impersonator:

In response to the allegations, this Spanish Agency for Data Protection must insist on the fact that, at no time has this agency questioned the contractual relationship existing between the parties and the legitimacy of BANCO in the processing of the personal data of the claiming party necessary for the contracting of financial products and services as a consequence of the formalization, management, and execution of the contractual relationship entered into by both.

However, in the present case, it has been established that the operations carried out were not conducted within the scope of the contractual relationship referred to by BANCO, since they were performed by a third party, without BANCO adequately verifying the identity of its interlocutor, resulting in the processing of the personal data of the claiming party without legitimacy.

BANCO continues to state,

Finally, it is worth noting the total omission regarding the conclusion reached in the Order issued on November 24, 2022, in the Preliminary Proceedings of the Summary Procedure (...) by the Investigating Court (...), where it was concluded that the perpetration of the crime was never duly justified, which is why the dismissal of the proceedings was agreed upon, a criterion not shared by the AEPD. For all these reasons, it is important to highlight that the right to the presumption of innocence, even in the context of administrative sanctioning law (SSTC 45/1997, of March 11, and 237/2002, of December 9), does not oppose the conviction of the sanctioning body being achieved through what is known as circumstantial evidence, a statement similar to that made by the European Court of Human Rights. In this regard, the distinction made by the Contentious-Administrative Chamber, Section 1 of the National Court, is relevant, which in its Judgment of June 25 addresses the differentiation between circumstantial evidence and mere suspicions or conjectures:

Moreover, when it comes to the so-called circumstantial evidence, the requirement of reasonableness in the connection between what is proven and what is presumed takes on special significance, since in these cases it is essential to prove not only that the underlying fact or indication has been proven, but that the reasoning, by virtue of which, starting from the proven indications, the conclusion has been reached that the accused engaged in the infringing conduct, is coherent, logical, and rational. In summary, it must be based on the rules of human judgment or on the rules of common experience. This, as we have said, is the only way to distinguish true circumstantial evidence from mere suspicions or conjectures, with the logical connection needing to be based on a "reasonable understanding of the normally lived and appreciated reality according to the prevailing collective criteria" (SSTC 45/1997, of March 11, F. 5; 237/2002, of December 9, F. 2, and 135/2003, of June 30, F. 2, among others).

And this is closely linked, as noted by the Honorable National Court, Section 1, of the Contentious Chamber in the ruling on the cassation appeal 104/2021, dated December 23, 2022, to the principle of certainty that must govern any process in accordance with the provisions of Article 25.1 of the CE. In light of this, the doctrine established in our judgment of April 29, 2019, is applicable to the present case. In that judgment, we referred to the principles of the sanctioning administrative procedure, such as the principle of legality, which according to the STS of May 28, 2009 (Rec. 172/2003), in accordance with the reiterated doctrine of the Constitutional Court, "translates into the imperative requirement of normative predetermination of unlawful conduct and the corresponding sanctions." This principle is a projection of the need for certainty that must guide the exercise of the sanctioning power of the Administration as provided in Article 25.1 CE and whose foundation lies in the respect for two

other values such as freedom and legal security.

In this regard, it should be emphasized that in the context of administrative sanctioning law, the principles inspiring criminal law apply, with some nuances, but without exceptions, and the principle of the presumption of innocence has full effect, which must govern without exceptions in the sanctioning legal framework and must be respected in the imposition of any sanctions. The Constitutional Court in its Judgment 76/1990 considers that the right to the presumption of innocence entails that the sanction must be based on acts or incriminating evidence of the reproached conduct; that the burden of proof lies with the accuser, without anyone being obliged to prove their own innocence; and that any insufficiency in the result of the evidence presented, freely assessed by the sanctioning body, must result in an acquittal.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/30

In conclusion, the principles governing the sanctioning procedure prevent the imputation of an administrative infraction when there has not been a minimum evidentiary burden demonstrating the facts that motivate this imputation or the involvement of BANCO PICHINCHA in the same, applying the principle "in dubio pro reo" in case of doubt regarding a specific and decisive fact, which in any case obliges to resolve such doubt in the most favorable manner for the interested party.

In accordance with this approach and in application of the provisions established by Article 53.2 of the LPACAP, this translates into the absence of administrative responsibility on the part of the Entity and, therefore, the impropriety of the sanction imposed for violation of the provisions of Article 6.1 of the RGPD, since, in no way, has it been possible for the AEPD to ascertain that the identity of the Claimant was ultimately usurped.

In response to the allegations, this body must record that it is absolutely respectful of the judicial decision of dismissal through the Order issued on November 24, 2022, in the Preliminary Proceedings of the Summary Procedure (...) by the Investigating Court (...).

However, it must be noted that the absence of criminal responsibility does not entail the absence of administrative responsibility.

The order of free dismissal issued in a criminal process does not bind the public Administration when imposing sanctions, because, as declared by the AN, it may be that the same facts do not warrant criminal reproach, but do warrant administrative reproach.

"The Constitutional Court has admitted that the circumstance that criminal proceedings have been dismissed, as is the case, does not prevent prosecution in the administrative sphere, when applicable rules of a different finalistic structure are taken into account, and therefore, with different efficacy or effects (Judgments 180/1988, of October 11, or 98/1989, of June 1)."

Also, the TS, in its STS No. 459/2017, of March 15, ECLI:ES:TS:2017:1186, states:

"(...) it cannot be maintained, as a consequence of the principle in question, the generic prohibition of an administrative sanctioning pronouncement, because what is excluded is double sanction and not double pronouncement. The acquittal in a criminal sentence does not block subsequent administrative sanctioning actions, but its declarations regarding the proven facts necessarily impact the administrative resolution (...)."

Regarding the principle of certainty alleged by the responding entity, the Royal Spanish Academy, in its Dictionary of Legal Spanish, defines the presumption of certainty or veracity as that reinforced evidentiary value that obliges the authority competent to sanction to understand that the facts declared are true unless proven otherwise.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/30

In the present case, it is recorded in the file and stated by the responding party that in the call made by

the GSS operator to the claiming party on September 6, the operator did not strictly adhere to the protocol established by BANCO, since "the supposed client" indicated during the call that she was unaware of the balance in her bank account, as well as having doubts about her profession. It is also proven in the file that, as a result of the call on September 6, the automatic process for the corresponding OTP code via SMS was initiated, allowing the change of password for Online Banking and carrying out various financial operations.

Therefore, following the breach by this third party of the existing security policy measures, new credentials were provided that allowed access to the personal data of the claiming party, which evidences a failure to protect client information.

Moreover, BANCO acknowledges the error by transferring responsibility to the Provider for failing to comply with the instructions provided by it.

"...Although, as evidenced, the Bank had reiterated on different occasions, and through various means, to its Provider what the procedure was for a client to recover their Online Banking credentials, as well as the specific instructions regarding the modus operandi of the operators in situations where the client does not respond accurately and clearly to the questions asked, in the call made by the GSS operator to Ms. A.A.A. on September 6, 2021, at 12:13 hours, said operator did not strictly comply with the protocol established by the Entity, since, despite the supposed client indicating during the call that she was unaware of the balance in her bank account, showing doubts in her response regarding her profession, the operator continued to ask more questions to the Claimant, ultimately initiating the automatic sending process of the corresponding OTP code via SMS to the phone number that the Complainant provided to the Bank at the time of account opening (let us remember that this number was verified by the Complainant herself at the time of contracting, as has been stated above), which would allow her to change the password for Online Banking.

In this regard, it is of interest to the Entity to inform this Agency that, despite it being a call that was later considered fraudulent, a fact of which the Bank became aware afterwards, through communications made by the Claimant days later, the Bank made available to the Provider all the necessary tools to strictly comply with current regulations, and having detected no signs of irregularity that would lead it to distrust a possible fraudulent contracting. In this sense, the Bank considers that, if there was a breach, it would be attributable to GSS, since Article 28.10 of the GDPR establishes that: "if a processor infringes this Regulation by determining the purposes and means of processing, it shall be considered responsible for the processing in relation to that processing."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
13/30

In light of the above, and as has been evidenced, the Provider failed to comply with the instructions provided by the Bank, thus acquiring the status of data processor...

Therefore, in this case, we cannot speak of indications or mere suspicions or conjectures, but rather of proven facts.

Furthermore, this body must remind the responding entity of the principle of proactive responsibility or accountability that the GDPR imposes on all data controllers, a principle defined as the necessity for the data controller to apply appropriate technical and organizational measures to ensure and be able to demonstrate that the processing is in compliance with the Regulation, a circumstance that has not occurred in our case.

In short, this principle requires a conscious, diligent, and proactive attitude from organizations regarding all personal data processing they carry out, an attitude that has not been present in this case.

The responding entity continues to state,

2. ON THE RESPONSIBILITY OF GSS AS THE DATA PROCESSOR OF THE ENTITY

By virtue of the above, it is indisputable that any type of liability towards BANCO PICHINCHA for the criminal actions carried out by a third party who used the Claimant's data to commit criminal acts against the Data Processor, namely GSS, is unfounded.

In this regard, Article 83 of the GDPR itself, concerning the general conditions for the imposition of administrative fines, includes, among other mentions, the following rules:

- c) any measures taken by the controller or processor to mitigate the damages suffered by the data subjects;
- d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have applied in accordance with Articles 25 and 32;
- e) any previous infringement committed by the controller or processor;
- h) the manner in which the supervisory authority became aware of the infringement, particularly whether the controller or processor notified the infringement and, if so, to what extent;
- i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the controller or processor in relation to the same matter, the compliance with such measures;

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/30

3. If a controller or processor intentionally or negligently violates various provisions of this Regulation for the same processing operations or related operations, the total amount of the administrative fine shall not exceed the amount provided for the most serious infringements.

In line with the above, the Agency refers in its Proposal for Resolution to Article 74 of the GDPR in relation to Recital 79, concluding that ultimate responsibility for the processing remains attributed to the controller, who determines the existence of the processing and its purpose. Indeed, in this matter, it has been established that BANCO PICHINCHA acted with due diligence by providing all necessary means to the Data Processor to ensure full compliance with the applicable regulations, without being able to exempt GSS from liability for acts or omissions that constitute unlawful conduct, since otherwise, the spirit of what is established in Articles 28 and 83 of the GDPR would clearly be lost. In conclusion, BANCO PICHINCHA cannot assume any fault for the breach of what is established by Article 6.1 of the GDPR, having also omitted the allegations made by this representation. Therefore, by virtue of what is established by the regulations, along with what is stipulated in Clause 7.3 of the Contract, the fact that GSS acted on its own, breaching the obligations agreed upon, directly makes it responsible for the processing of the Claimant's personal data.

In response to what has been stated by the responding entity, this Spanish Agency for Data Protection must clarify and emphasize that in the Proposal for Resolution reference is made to Recital 74 of the GDPR and Recital 79 of the GDPR and not to Article 74 of the GDPR in relation to Recital 79 of the same legal text.

This body must insist on what is provided in Recital 74 of the GDPR, which establishes: The responsibility of the data controller must be established for any processing of personal data carried out by itself or on its behalf. In particular, the controller must be obliged to apply appropriate and effective measures and must be able to demonstrate the compliance of the processing activities with this Regulation, including the effectiveness of the measures. Such measures must take into account the nature, scope, context, and purposes of the processing as well as the risk to the rights and freedoms of natural persons. Likewise, Recital 79 states: The protection of the rights and freedoms of data subjects, as well as the responsibility of controllers and processors, also regarding the supervision by the supervisory authorities and the measures taken by them, require a clear attribution of responsibilities under this Regulation, including cases where a controller determines the purposes and means of processing jointly with...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/30

other responsible parties, or in cases where the processing is carried out on behalf of a responsible

party.

Therefore, it is clear that ultimate responsibility for the processing remains with the responsible party, who determines the existence of the processing and its purpose.

BANCO continues by stating that,

3. NON-EXISTENCE OF INTENT OR NEGLIGENCE ON THE PART OF BANCO PICHINCHA THAT WOULD ALLOW FOR THE IMPOSITION OF AN ADMINISTRATIVE FINE

The jurisprudence established in our country is not recent, which has been determining that for an action to be sanctioned, there must exist and, therefore, the control authority must demonstrate, since the burden of proof lies with it, that there is a certain degree of intent. (STC No. 76/1990 of April 26). Likewise, the Judgment of the Administrative Litigation Chamber of the National Court, Section 1, of December 23, 2013, Rec. 341/2012:

Indeed, in sanctioning matters, the principle of culpability applies (SSTC 15/1999, of July 4; 76/1990, of April 26; and 246/1991, of December 19), which means that some kind of intent or fault must be present. As stated in the Supreme Court ruling of January 23, 1998, ...one can speak of a decisive line of jurisprudence that rejects objective liability in the administrative sanctioning sphere, requiring the concurrence of intent or fault, in line with the interpretation of STC 76/1990, of April 26, by indicating that the principle of culpability can be inferred from the principles of legality and prohibition of excess (Article 25 of the Constitution) or from the inherent requirements of the Rule of Law.

And, in the same vein, the National Court, Administrative Chamber, expressed itself in its Judgment of February 25, 2010, No. of Recourse 226/2009:

The LOPD establishes an obligation of result, consisting of adopting the necessary measures to prevent data from being lost, misplaced, or ending up in the hands of third parties; such obligation is not absolute and cannot encompass a case like the one analyzed. In the case at hand, the result is a consequence of an intrusion activity, not covered by legal provisions and thus illegal, by a third party with high technical computer knowledge who, breaking the established security systems, accesses the database of registered users at www.portalatino.com, downloading a copy of it. And, such facts cannot be attributed to the appealing entity since, otherwise, the principle of culpability would be violated.

Both the present matter and the one analyzed in the detailed Judgment have as a common denominator an illegal intrusion committed by third parties with a high degree of computer knowledge and who act in an organized manner, thereby violating the principles enshrined in our Penal Code.

Having said all of the above, it is necessary to bring to attention the recent ruling in cases C-683/21 | Nacionalinis visuomenės sveikatos centras and C-807/21 | Deutsche Wohnen, dated December 5, 2023, issued by the Court of Justice of the European Union (hereinafter, “CJEU”), which states that the amounts determined in this Procedure must be declared null, determining that a fine can only be imposed if the alleged infringement has occurred intentionally or negligently.

The Lithuanian government and the Council of the European Union deduce from this that the Union legislator intended to leave Member States a certain margin of appreciation in the application of Article 83 of the GDPR, allowing them to foresee the imposition of administrative fines under that provision, where applicable, without proving that the infringement of the GDPR sanctioned by such fine was committed intentionally or negligently. Notwithstanding the above, this extensive interpretation of the sanctioning power granted by the GDPR has again been categorized as unacceptable, specifically by the CJEU, in its recent Judgments regarding cases C-683/21 [1] (Nacionalinis visuomenės sveikatos centras) and C-807/21 [2] (Deutsche Wohnen).

And specifically in case C-683/2021, the CJEU stipulates:

The Lithuanian government and the Council of the European Union deduce from this that the Union legislator intended to leave Member States a certain margin of appreciation in the application of Article 83 of the GDPR, allowing them to foresee the imposition of administrative fines under that provision, where applicable, without proving that the infringement of the GDPR sanctioned by such fine was committed deliberately or by negligence. Such an interpretation of Article 83 of the GDPR cannot be accepted.

And it continues:

...nothing in the literal wording of Article 83, paragraphs 1 to 6, of the GDPR indicates that the Union legislator intended to leave a margin of appreciation to Member States regarding the material

requirements that a control authority must meet when deciding to impose an administrative fine on a data controller for an infringement covered in paragraphs 4 to 6 of that article.

This finding is also corroborated by the joint reading of Articles 83 and 84 of the GDPR. Indeed, Article C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/30

84, paragraph 1, of said Regulation allows Member States to retain the authority to determine the regime of other sanctions applicable in the event of a breach of said Regulation, particularly for breaches that are not subject to the administrative fines provided for in Article 83. From this joint reading of these provisions, it follows that the determination of the material conditions under which such administrative fines may be imposed is outside of that competence. Therefore, these conditions fall exclusively under Union Law.

Regarding these requirements, it should be noted that Article 83, paragraph 2, of the GDPR enumerates the elements based on which the supervisory authority imposes an administrative fine on the data controller. Subparagraph b) of this provision includes the fact that the infringement was committed intentionally or negligently. Furthermore, none of the factors listed in this provision mentions the possibility that the data controller may be held liable in the absence of culpable conduct on their part.

Thus, the CJEU expressly establishes that neither the national legislator nor the administrative authority will have the capacity to alter or modify the material requirements that must be met to impose an administrative fine under the GDPR. And, these material conditions, which must necessarily be present for the imposition of an administrative sanction, materialize in the culpable or deliberate action (or omission) of the data controller:

Therefore, from the literal wording of Article 83, paragraph 2, of the GDPR, it follows that only breaches of the provisions of said Regulation committed culpably by the data controller, that is, those committed deliberately or through negligence, may give rise to the imposition of an administrative fine on the data controller under said article.

Consequently, it should be declared that Article 83 of the GDPR does not allow for the imposition of an administrative fine for an infringement covered in paragraphs 4 to 6 of said article without it being demonstrated that such infringement was committed deliberately or through negligence by the data controller and that, therefore, the existence of a culpable infringement constitutes a requirement for the imposition of such a fine.

It is only possible to impose administrative sanctions based on the GDPR when the competent administrative authority has duly established the occurrence of a culpable, intentional (willful) or negligent act by the DATA CONTROLLER, SOMETHING THAT HAS NOT OCCURRED IN THE PRESENT PROCEEDING.

Therefore, since the occurrence of a culpable, intentional or negligent act by BANCO PICHINCHA has not been established, not

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/30

proceed to identify in the conduct of this party an infringement of the personal data protection regulations under the GDPR.

Considering the content of this allegation, it is in the interest of this party's rights that the competent authority to which we are addressing agrees to suspend the effects of the Proposal for Resolution regarding the allocation of the amounts derived from the alleged commission of the infringements typified in Article 83.4 of the GDPR, in application of Article 117 of the LPACAP.

In response to the allegations made, this Spanish Agency for Data Protection cannot agree more that there can be no economic sanction if there is no concurrence of intent or negligence in the

infringement. However, the responding party errs in understanding that there has been no negligent conduct on its part.

To this end, it is necessary to refer to the invoked Judgment of the Court of Justice of the European Union, dated December 5, 2023, in the case C-807/21 (Deutsche Wohnen), which states:

“76 In this regard, it should also be specified, concerning the question of whether an infringement has been committed intentionally or negligently and, therefore, can be sanctioned with an administrative fine under Article 83 of the GDPR, that a data controller can be sanctioned for behavior falling within the scope of the GDPR when it could not ignore the infringing nature of its conduct, whether or not it was aware of infringing the provisions of the GDPR (see, by analogy, the judgments of June 18, 2013, Schenker & Co. and others, C 681/11, EU:C:2013:404, paragraph 37 and cited case law; of March 25, 2021, Lundbeck/Commission, C 591/16 P, EU:C:2021:243, paragraph 156, and of March 25, 2021, Arrow Group and Arrow Generics/Commission, C 601/16 P, EU:C:2021:244, paragraph 97).” (the underlining is ours).

In the same vein, the judicial bodies of our country express themselves. Thus, the Judgment of the National Court, dated January 21, 2010, states:

“The appellant also maintains that there is no culpability in its actions. It is true that the principle of culpability prevents the admission in sanctioning administrative law of objective responsibility; it is also true that the absence of intent is secondary since this type of infringement is usually committed by a culpable or negligent act, which is sufficient to integrate the subjective element of fault. The conduct of XXX is clearly negligent since... it must know... the obligations imposed by the LOPD on all those who handle personal data of third parties. XXX is obliged to guarantee the fundamental right to the protection of personal data of its clients and hypothetical clients with the intensity required by the content of the right itself.”

The events that occurred demonstrate that BANCO did not act with the diligence it was obliged to, that it acted with a lack of diligence. To understand otherwise would mean:

- In the case of the infringement of Article 32 of the GDPR, that the data controller will never be held responsible for the unlawful actions regarding personal data protection carried out by its data processor, when already

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

19/30

we have indicated in the previous legal basis that it can indeed be held liable for such actions.

The Supreme Court (Judgments of April 16 and 22, 1991) considers that from the culpability element it follows that “...the action or omission, classified as an administratively sanctionable infringement, must, in any case, be attributable to its author, whether by intent or negligence, imprudence, or inexcusable ignorance.” The same Court reasons that “it is not enough... for exculpation against a typically unlawful behavior to invoke the absence of fault” but rather “it is necessary that the diligence required by the one claiming its non-existence has been employed” (STS January 23, 1998).

Also connected with the degree of diligence that the data controller is obliged to exercise in fulfilling the obligations imposed by data protection regulations is the Judgment of the National Court of October 17, 2007 (Rec. 63/2006), which specified: “(...) the Supreme Court has understood that there is negligence whenever a legal duty of care is neglected, that is, when the offender does not behave with the required diligence.”

Furthermore, the National Court in matters of personal data protection has declared that “simple negligence or failure to comply with the duties imposed by the Law on the persons responsible for files or data processing to exercise extreme diligence is sufficient...” (Judgment of the National Court of June 29, 2001).

The entity being claimed continues,

4. VIOLATION OF THE PRINCIPLE OF PROPORTIONALITY REGARDING THE PROPOSED ECONOMIC SANCTION

This party considers that, having demonstrated that BANCO PICHINCHA acted diligently, observing the obligations of a data controller and having processed the Claimant's data in accordance with the Law, the sanction imposed by the AEPD is, clearly, disproportionate and notably deviates from the principles established by settled case law, in relation to the due observance of what is established by Article 29 of Law 40/2015 on the Public Sector Regime (hereinafter, the "LRJSP"), which the AEPD determines is not applicable to the sanctioning regime imposed by the GDPR because the GDPR is a complete system:

The principle of proportionality, as noted by the STS of June 2, 2003, tends to adjust the sanction, by establishing its specific gradation within the possible margins, to the severity of the act constituting the infringement, both in its aspect of unlawfulness and culpability, weighing in its entirety the objective and subjective circumstances that integrate the budget of sanctionable fact and, in particular, as results from Article 131.3 of Law 30/92, the intentionality or repetition, the nature of the damages caused, and the recidivism. (STS June 6, 2007)

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
20/30

It is necessary to reiterate that, although the AEPD frequently mentions the assessment of the specific circumstances of the case, it is true that there is no express mention of the specific factual elements in which the AEPD identifies a lack of diligence on the part of my represented party, when in any case, it has been the Data Processor, that is, GSS, who has failed to comply with the instructions of the data controller. Consequently, reference must be made to the principle of culpability that governs the sanctioning procedure (see, among others, STC 15/1999, of July 4; 76/1990, of April 26; and 246/1991, of December 19) and which determines that there must necessarily be some kind of intent or fault on the part of the Entity for it to be sanctioned, as we have mentioned in previous points. Thus, reference must be made to what is established by Article 28 of the LRJSP, which states:

Only individuals and legal entities, as well as, when a law recognizes their capacity to act, groups of affected individuals, unions and entities without legal personality, and independent or autonomous estates, that are found responsible for the same by way of intent or fault, may be sanctioned for acts constituting administrative infractions.

In the same vein, despite the justifications presented by the AEPD, although the GDPR may foresee that imposed sanctions may be deterrent, it in no case refers to them being confiscatory. When establishing the maximum limits of the sanctions, the regulation refers to a cap of 20 million euros or 4% of the turnover of the data controller.

It is obvious that the quantitative limit of 20 million is stipulated for serious infractions committed by entities with immense economic capacity, for which a lesser sanction may not be prohibitive to comply with the regulation.

However, this broad quantitative margin that the regulation must encompass cannot serve as a pretext to impose disproportionate sanctions, thus notably deviating from the principles established by settled jurisprudence, in relation to the due observance of what is established by Article 29 of the LRJSP:

The principle of proportionality, as noted by the STS of June 2, 2003, aims to adjust the sanction, by establishing its specific gradation within the possible margins, to the severity of the act constituting the infraction, both in its aspect of unlawfulness and culpability, weighing in its entirety the objective and subjective circumstances that make up the budget of the sanctionable fact and, in particular, as results from Article 131.3 of Law 30/92, the intent or repetition, the nature of the damages caused, and recidivism. (STS June 6, 2007).

For all the above reasons, this party considers that the proposed sanction is not appropriate and, in the hypothetical case that it were appropriate, it would not be proportional to the case at hand.

Furthermore, in accordance with Recital 146 of the GDPR, the imposition of sanctions, including administrative fines, must be subject to sufficient procedural guarantees in accordance with the general principles of Law.

C/ Jorge Juan, 6

Union and the Charter, including the right to effective judicial protection and to a process with all guarantees.

That said, this Agency overlooks that mens rea is generally required to impose a criminal sanction and that, therefore, objective liability constitutes a kind of "exception" to this general rule, insofar as it must be justified in light of the objectives pursued by the Regulation.

Therefore, the AEPD—unilaterally—decides not to apply the key criteria governing the relationship between the offense and the sanction, concluding in a discretionary action, once again contravening the principle of proportionality, as established by the Judgment of the Supreme Court, Chamber 3, of Administrative Litigation, October 27, 1986:

...the principle of proportionality prevents the absolute discretion of the Administration in choosing the sanction to impose.

Similarly, the AEPD argues based on Guidelines 04/2022 on the calculation of administrative fines under the GDPR, in its version 2.1, adopted on May 24, 2023 (hereinafter, interchangeably, the "Guidelines 04/2022" or the "Guidelines"), that cooperation should be considered a neutral and not mitigating factor. However, the AEPD does not take into account the entirety of what is established by the Guidelines 04/2022 by overlooking the following: However, when cooperation with the supervisory authority has had the effect of limiting or avoiding negative consequences for the rights of individuals that could otherwise have occurred, the supervisory authority may consider this a mitigating factor in the sense of Article 83, paragraph 2, letter f), of the GDPR, thus reducing the amount of the fine. This may be the case, for example, when a data controller or processor "has specifically responded to the requests of the supervisory authority during the investigation phase in that specific case, which has significantly limited the impact on the rights of individuals as a result."

Imposing on BANCO PICHINCHA the responsibilities of the Data Processor implies that the Agency has not taken into account the totality of the objective and subjective circumstances that comprise the facts, which means that the sanction has been determined based on the characteristics of the Entity and not based on the facts, something that is not only a flagrant violation of the principle of proportionality but also calls into question the principle of legal certainty, as well as equality, thereby violating both Article 29 of the LRJSP and Article 83 of the GDPR. Thus, it is worth recalling that the High Court of Justice establishes that:

the principle of proportionality, as noted in the STS of June 2, 2003, tends to adjust the sanction, by establishing its specific gradation within the possible margins, to the severity of the act constituting the infringement, both in its aspect of unlawfulness and culpability, weighing in its entirety the objective and subjective circumstances that comprise the sanctionable factual presumption and, in particular, as results from Article 131.3 of Law 30/92, the intentionality or

reiteration, the nature of the damages caused, and the recidivism. (STS June 6, 2007).

And it is that once again the element mentioned in Article 83.2.b) of the GDPR comes into play, relating to negligence or culpability, which has not been duly observed by the supervisory authority. Regarding the aggravating factor applied and related to the link between the infringer's activity and the processing of personal data, the Agency bases its argument on the fact that BANCO PICHINCHA, in the exercise of its financial activity, must have consent and legitimacy in the processing of its clients' personal data.

An aggravating factor that is clearly inappropriate given the proper processing of personal data carried out by the Entity— a fact that has been duly accredited as evidenced in Legal Basis III of the Proposal for Resolution— since, as stated above, the person who should have sufficient legitimacy to carry out

the processing of the Claimant's data was the impersonator, making it impossible to conclude that BANCO PICHINCHA violated any of the legal foundations established in Article 6 of the GDPR. That said, this party wants to emphasize once again that an entity like BANCO PICHINCHA carries out a large volume of personal data processing and that this is the only existing complaint should be a positive aspect to be valued by this Agency.

Applying the principle of proportionality, the severity of the act is practically nonexistent, considering that the amounts were returned to the Claimant, as well as actions were taken against the Data Processor as a consequence of the non-compliance with the instructions of the data controller, which undoubtedly implies that the damages caused are null and that the Entity acted under the principle of proactive responsibility of Article 5.2 of the GDPR. The fact that BANCO PICHINCHA processes personal data as a consequence of its activity cannot be used as a catch-all.

It cannot, in fact, be considered that the same amount of the monetary sanction, variable depending on the intensity of the unlawful component of the facts, remains proportionate whether it concerns two or two thousand cases: if the facts for which the sanction is deemed appropriate are ultimately reduced, by virtue of the powers of appreciation of the Chamber, to a negligible percentage compared to those that the Administration considered proven, the requirements of the principle of proportionality applied consistently by this Chamber (and now positivized in sanctioning matters by Article 131 of Law 30/1992) prevented maintaining the sanction as it was imposed by the contested resolution. (Judgment TS June 6, 2007)

In this same sense, the Supreme Court in its Judgment of July 29, 2014 (Contentious-Administrative Chamber, Section 1), stated that:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

23/30

The principle of proportionality plays a capital role in the field of Administrative Sanctioning Law, not only as an expression of abstract powers of law enforcement in terms of equity but also due to the concrete fact that the sanctions to be imposed are defined in our legal system, generally, in a highly flexible manner, so that the same conduct may warrant the imposition of very diverse sanctions that move within very broad margins and that, for the same reason, may result, in practice, in extraordinarily diverse amounts and periods. The principle of proportionality imposes that since the sanctioning activity of the Administration is not a discretionary activity, but a typically legal activity or application of the norms, (as recognized by our Supreme Court in Judgments of December 23, 1981 [RJ 1981, 5453], February 3, 1984 [RJ 1984, 1027], and April 19, 1985 [RJ 1985, 1716]), the factors that must preside over its application are based on what the Legal System provides in each particular sector and, very especially, in the concurrent circumstances.

The recent judgment of the National Court, Contentious-Administrative Chamber, Section 1, Judgment of May 13, 2024, Rec. 2336/2021

Thus, in accordance with such a principle of proportionality, taking into consideration the nature and severity of the infringement, the number of affected parties, the level of damages and losses suffered, the intent or negligence, the degree of responsibility, the previous infringements committed by the same Vodafone, as well as the category of the affected personal data and the link of its activity with the processing of personal data, the Chamber concludes that it is proportionate to reduce the imposed administrative fine.

In response to the statements made, it must first be noted that Article 83.5 of the GDPR provides: "Violations of the following provisions shall be subject to administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)"

While Article 83.4 of the GDPR provides:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
24/30

“Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of a company, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the data controller and the data processor pursuant to Articles 8, 11, 25 to 39, 42, and 43; (...)”

Therefore, a fine of:

- 50,000 euros, in the case of the violation of Article 6.1 of the GDPR,

is at the lower end of the possible sanctions, thus complying with Article 83.1 of the aforementioned GDPR: “Each supervisory authority shall ensure that the imposition of administrative fines under this article for the violations of this Regulation indicated in paragraphs 4, 5, and 6 are in each individual case effective, proportionate, and dissuasive.”

Finally, regarding the payment of the amounts referred to in your written allegations, it seems necessary to clarify that this possibility is not contemplated in Spanish administrative sanctioning law. This is because, according to the provisions of Article 88 of the LPACAP, the conclusion of an administrative procedure occurs with the resolution of the same. In particular, and by virtue of the provisions of Article 90 of that same regulation, in the case of sanctioning procedures, the resolution that concludes the procedure shall be executive when no ordinary appeal can be made against it in the administrative route, and it may adopt the necessary precautionary measures to ensure its effectiveness as long as it is not executive, which may consist of maintaining the provisional measures that may have been adopted. Moreover, such executivity may be suspended in the event that the interested party expresses to the Administration their intention to file a contentious-administrative appeal against the firm resolution in the administrative route.

Consequently, the hearing procedure following the issuance of the proposal for allegations in a sanctioning procedure can never be considered the appropriate procedural moment for the consignment of a potential sanction that has not yet become firm.

This is clearly stated in Article 98 of the LPACAP, which directly refers to the birth of the obligation to pay as a consequence of the resolution of the procedure and determines the means through which it must be satisfied.

For all the above reasons and in order to return the undue payment, it is requested that a bank account be provided to which the amounts unduly paid can be transferred.

For all the reasons stated, the allegations are DISMISSED.

IV

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
25/30

Article 6.1 of the GDPR

Article 6 of the GDPR establishes, regarding the lawfulness of the processing of personal data obtained from users, that such processing shall only be lawful if at least one of the conditions set out in its first paragraph is met, among which, in paragraph a), is: “that the data subject has given consent to the processing of their personal data for one or more specific purposes (...)”.

Regarding the processing of data based on the consent of the data subject, Article 7 of the GDPR indicates that the data controller must be able to demonstrate that the data subject consented to the processing of their personal data. If consent is given in the context of a written declaration that also refers to other matters, it must be ensured that the request for consent is clearly distinguishable from other matters and presented in an intelligible manner, easily accessible, and using clear and plain

language. Additionally, it is required that additional information is provided to the data subject, including, among others, what categories of data will be processed, the purposes for which consent is requested, and the right to withdraw consent at any time.

Regarding the manner of obtaining the consent of the data subject for the processing in question, Recital 32 of the GDPR states that consent “must be given by a clear affirmative act that reflects the data subject's free, specific, informed, and unambiguous indication of their wishes to accept the processing of personal data concerning them” and that “silence, pre-ticked boxes, or inactivity should not constitute consent.” It is also required that consent is given “for all processing activities carried out for the same or similar purposes. When processing has multiple purposes, consent must be given for all of them.” Finally, it establishes that “if the data subject's consent is to be given as a result of a request by electronic means, the request must be clear, concise, and not unnecessarily disrupt the use of the service for which it is provided.”

For its part, Article 12.1 of the aforementioned GDPR establishes, regarding the requirements that the information provided by the data controller to the data subjects when requesting their consent must meet, the following: “1. The data controller shall take appropriate measures to provide the data subject with all information indicated in Articles 13 and 14, as well as any communication in accordance with Articles 15 to 22 and 34 related to the processing, in a concise, transparent, intelligible, and easily accessible form, using clear and plain language, particularly any information specifically addressed to a child. The information shall be provided in writing or by other means, including, where appropriate, by electronic means. When requested by the data subject, the information may be provided verbally, provided that the identity of the data subject is demonstrated by other means (...).”

Articles 13 and 14 of the GDPR detail, for their part, the information that must be provided to the data subject when the data is collected directly from them (Art. 13), or through other means (Art. 14). In any case, the obligation to inform data subjects about the circumstances relating to the processing of their data rests with the data controller: a) If the data is obtained directly from the data subject, the information must be made available at the time the data is requested, prior to collection or recording; and b) if it is not obtained from the data subject.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

26/30

the interested party, must be informed within one month from the date the personal data was obtained, or before or at the first communication with the interested party, or before the data (if applicable) has been communicated to other recipients.

In this case, there are various calls made to the banking entity BANCO to carry out certain operations, following a change of credentials, which resulted in a total of 50,000 euros transferred from the claimant's bank account to other accounts. All of this occurred without their authorization or consent, considering that the regulations regarding the protection of personal data have been violated.

The reported facts materialize in the identity theft of the claimant by a third party.

In this case, according to the statement of the claimant, the cloning of the phone was requested and without properly following the security procedure for changing passwords, a third party made various calls to BANCO to carry out certain operations that resulted in a total of 50,000 euros transferred from their bank account to other accounts.

Furthermore, BANCO acknowledges the error by transferring responsibility to the Provider for failing to comply with the instructions provided by it.

“...Although, as evidenced, the Bank had reiterated on different occasions, and through various means, to its Provider what the procedure was for a customer to recover their Online Banking passwords, as well as the specific instructions regarding the modus operandi of the operators in situations where the customer does not respond accurately and clearly to the questions asked, in the call made by the GSS operator to Ms. A.A.A. on September 6, 2021, at 12:13 hours, said operator did not strictly comply with the protocol established by the Entity, since, despite the supposed customer indicating in the call that they were unaware of the balance in their bank account, showing doubts in

response to what their profession was, the operator continued to ask more questions to the Claimant, ultimately initiating the process of automatically sending the corresponding OTP code via SMS to the phone number that the Complainant provided to the Bank at the time of account opening (let us remember that this number was verified by the Claimant at the time of contracting, as has been stated above), which would allow them to change the Online Banking password.

In this regard, it is of interest to the Entity to inform this Agency that, despite it being a call that was later considered fraudulent, a fact of which the Bank became aware afterwards, through communications made by the Claimant days later, the Bank made all the necessary tools available to the Provider to strictly comply with the current regulations, and having detected no signs of irregularity that would lead them to distrust a possible fraudulent contracting. In this sense, the Bank considers that, if there was a breach, it would be attributable to GSS, since Article 28.10 of the GDPR states that: "if a processor infringes this Regulation by determining the purposes and means of processing, it shall be considered responsible for the processing in relation to that processing."

In light of the above, and as has been evidenced, the Provider failed to comply with the instructions provided by the Bank, thus acquiring the status of data controller in this case..."

Consequently, it is considered that the known facts constitute an infringement, attributable to BANCO, for violation of Article 6.1 of the GDPR, since the processing of the claimant's data has been carried out without a legitimate basis as it was not correctly verified that the person to whom the data was provided was its owner, being, in fact, a third party to whom the claimant's data was provided.

V

Qualification of the infringement of Article 6.1 of the GDPR

The aforementioned infringement of Article 6.1 of the GDPR constitutes the commission of the infringements classified in Article 83.5 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" states:

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of an undertaking, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements" establishes that "Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the purposes of the statute of limitations, Article 72 "Infringements considered very serious" of the LOPDGDD indicates:

"1. Based on what is established in Article 83.5 of Regulation (EU) 2016/679, the following are considered very serious and shall prescribe after three years: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

b) The processing of personal data without any of the conditions for legitimacy established in Article 6 of Regulation (EU) 2016/679. (...)"

28/30

VI

Sanction for the infringement of Article 6.1 of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, it is necessary to graduate the sanction to be imposed in accordance with the following criteria established in Article 83.2 of the GDPR:

As aggravating factors:

-

b) the intentionality or negligence in the infringement;

In this same sense, the Supreme Court has understood that there is negligence whenever a legal duty of care is disregarded, that is, when the offender does not behave with the required diligence. In assessing the degree of diligence, particular emphasis must be placed on the professionalism or lack thereof of the subject, and there is no doubt that, in the case now examined, when the activity of the

appellant involves constant and abundant handling of personal data, it must be insisted upon that rigor and exquisite care be taken to comply with the legal provisions in this regard. [Judgment of the National Court of 17/10/2007 (rec. 63/2006)]

As aggravating factors:

-

b) The connection of the offender's activity with the processing of personal data.

The BANK, in exercising its financial activity, must have the consent and legitimacy in the processing of its clients' personal data.

Consequently, and for the purpose of complying with the legally established requirements, the exercise of such activity necessarily implies knowledge and application of the current regulations regarding personal data protection.

The balance of the circumstances contemplated in Article 83.2 of the GDPR and Article 76.2 of the LOPDGDD, with respect to the infringement committed by violating the provisions established in Article 6.1 of the GDPR, allows for the imposition of a sanction of €50,000 (FIFTY THOUSAND EUROS).

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established,

the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on BANCO PICHINCHA ESPAÑA, S.A., with NIF A85882330, for an infringement of Article 6.1 of the GDPR, classified under Article 83.5 of the GDPR, a fine of €50,000 (FIFTY THOUSAND EUROS).

SECOND: TO DECLARE the lack of effects of the deposit

THIRD: TO NOTIFY this resolution to BANCO PICHINCHA ESPAÑA, S.A.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

29/30

FOURTH: This resolution shall be enforceable once the period for filing the optional appeal for reconsideration (one month from the day following the notification of this resolution) has expired without the interested party having exercised this right. The sanctioned party is warned that they must comply with the imposed sanction once this resolution becomes enforceable, in accordance with the provisions of Article 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), within the voluntary payment period established in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003, of December 17, by making the payment, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, into the restricted account No.

IBAN: ES00-0000-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX), opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A. Otherwise, collection will proceed in the executive period.

Upon receipt of the notification and once enforceable, if the date of enforceability falls between the 1st and the 15th of each month, inclusive, the deadline for making the voluntary payment will be until the 20th of the following month or the next business day thereafter, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second following month or the next business day thereafter.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file an appeal for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of

Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency is not aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

30/30

938-16012024

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es